

Uganda Paygate

Complete System Reference & React + NestJS Rebuild Guide

ICEA LION travel-insurance platform (Kenya / Uganda / Tanzania) — reverse-engineered from the Symfony 7 / PHP 8.2 codebase and its MySQL schema.

Prepared for rebuild planning. Generated 2026-07-27.

Contents

- 1. Executive Summary
- 2. Current Tech Stack
- 3. Authentication & Authorization (as-is), with security issues
- 4. Core Business Workflow — Quote → Price → Pay → Issue
- 5. Database Schema
- 6. Backend Route / API Inventory
- 7. External Integrations
- 8. Frontend Sitemap (Public / Admin / Broker)
- 9. Design System — Colors, Typography, Layout (KEEP for rebuild)
- 10. Known Bugs & Legacy Issues (do NOT replicate)
- 11. UX Pain Points (rebuild backlog)
- 12. Recommended NestJS Backend Architecture
- 13. Recommended React Frontend Architecture
- 14. Rebuild Checklist / Milestones

1. Executive Summary

This is **ICEA LION's travel-insurance sales & issuance platform**, serving three regions (Kenya, Uganda, Tanzania) with one primary focus in this codebase: the **Uganda market** (mobile-money checkout via MTN/Airtel). It lets a customer get an instant travel-insurance quote, buy a policy, pay by mobile money or card, and receive a PDF certificate with a QR-verifiable code — or lets a broker/agency book on a customer's behalf, either paid up-front or billed on credit against a corporate account.

It is built as a monolithic **Symfony 7 (PHP 8.2)** server-rendered app: Twig templates, Doctrine ORM (used inconsistently — most real logic is raw SQL in Repository classes), MySQL, and legacy jQuery for interactivity. There is **no real API layer** and **no Symfony security firewall in use** — authentication is a hand-rolled JWT + PHP session hybrid with substantial gaps (see §3).

Two pricing/issuance engines run in parallel: a legacy local rate-table lookup (`Travelrates` + `Calculationvariables`) used for instant quote calculators and reporting, and a newer, authoritative external system — **Cygnets IMS v5** — which actually prices and issues the policy of record. Payment goes through ICEA's own **"Uganda Paygate"** mobile-money API (not a third-party gateway despite the name), with legacy Pesapal (card, Kenya) and dormant Selcom/iotec.io (Tanzania mobile-money) integrations still present in code.

For the rebuild: the database and business rules are the valuable, portable asset. The PHP controllers are extremely large (multiple 2,000–5,500-line files), contain dead code, duplicated logic, and real bugs (wrong-currency conversion, disabled auth checks, assignment-instead-of-comparison bugs). Treat this document's §10 as a "do not copy" list and §12–13 as the target architecture, not a literal port.

2. Current Tech Stack

Layer	Current implementation
Language/Framework	PHP 8.2, Symfony 7.4
ORM/DB	Doctrine ORM/DBAL 3, MySQL (mostly InnoDB, one MyISAM table); no migration history — schema evolved by hand
Templating	Twig, 8 near-duplicate layout shells
Frontend interactivity	Legacy jQuery (Stimulus/Turbo/asset-mapper are installed but effectively dead/unused)
Public site UI kit	Custom Bootstrap-family theme, Select2, daterangepicker, Vegas.js slider
Admin & Broker UI kit	AdminLTE 2.x + DataTables + pace.js loader
PDF generation	Dompdf (3 separate/duplicated code paths — see §10)
QR codes	Endroid QR-Code (certificate/embassy-letter verification)
Email	PHPMailer over Gmail SMTP, credentials stored in a DB config table
Auth	Hand-rolled JWT (vendored php-jwt clone) + native PHP session hybrid; no Symfony Security component in use
External insurer system	Cygnets IMS v5 (pricing + policy issuance of record)
Payments	ICEA's own "Uganda Paygate" mobile-money API (primary); Pesapal (legacy card/Kenya); Selcom & iotec.io (dormant, Tanzania)

3. Authentication & Authorization (as-is)

No Symfony security firewall is actually active. `security.yaml` defines an empty `main` firewall with `provider: users_in_memory` and no authenticators; `access_control` is commented out. All auth is hand-rolled across `JWT.php`, `SessionController.php`, and ad-hoc per-controller checks.

3.1 Identity model

Identity	Storage	Login route	JWT role claim	Notes
Admin (staff)	<code>admins</code> table	<code>/loginAction</code>	<code>admin</code>	Role: 1 = Super User, 2 = Admin (int column, no granular permission enforcement)
Broker/agent	same <code>admins</code> table	<code>/brokerloginAction</code>	<code>broker</code>	Differentiated by a role/type value, not a separate entity
Client (customer)	<code>clients</code> table	<code>/felogin</code>	<code>client</code>	<code>isbroker</code> flag lets a client account act as a broker-style user front-end
Corporate account	<code>coopaccounts</code> , under a <code>clients.parentagency / intmed</code>	n/a — not a login identity	n/a	Billed on credit at a flat daily rate; bookings issue documents immediately, no payment gateway call

3.2 JWT layer

- Vendored clone of `firebase/php-jwt v5` (not a Composer package). Only HS256 is actually used.
- `exp / nbf` stored as formatted date strings, not Unix timestamps — non-standard.
- Token issued with 55-minute expiry, carried in the JSON response body and re-sent as a `token` field in POST bodies/query strings (not an `Authorization` header, except in the newer `TravelApiController`).
- Secret: `JWT_SECRET` env var — **the literal signing secret is committed in `.env / .env.local`**.

Critical bug — expiry not enforced. When a token is expired, `JWT::decode()` does not throw; it mutates the payload (`exp=''` , `sts='expired token'`) and returns it anyway. The throw is commented out. Callers must remember to check `sts === 'expired token'` — most don't.

Critical bug — silent auth failure returns 0, not a rejection.

`SessionController::getUserId($token)` returns `0` on any failure (expired/malformed/missing) instead of throwing/rejecting. The large majority of "protected" AJAX endpoints across `AdminController` , `BrokerController` , `IndexController` , `PurchasesController` fetch `$userid` this way and **never check it's `> 0`** before reading/writing data — meaning an endpoint reachable with `token=anything` executes as user 0. Only ~2 of ~90 `AdminController` AJAX routes call the (rarely used) `isAdmin()` check.

3.3 Other parallel "security" mechanisms (inconsistent, weak)

- **Native PHP `$_SESSION`** is also set on login (largely vestigial; used only to gate full-page Twig renders via a per-controller `verifySession()` helper).
- `encodeLab.php` — AES-256-CBC with a hardcoded key literal `'God Bless Kenya'` , no MAC — used to obfuscate numeric IDs in URLs across dozens of call sites. A third, unrelated identity path (`IndexController::savePrintRate()`) decrypts a `userid` with this instead of a JWT.
- **Passwords are unsalted `ripemd160` hashes everywhere** (admin, broker, client) — must become `bcrypt/argon2id` in the rebuild.
- `OrmOvr.php` (PBKDF2 helper, hardcoded salt) and `OAuthController.php` (789 lines, duplicate legacy OAuth1 library) are entirely dead code, never invoked — safe to omit.
- `src/OAuthClient/*` is the **actively used** OAuth 1.0a consumer library, used only to sign requests to Pesapal (this app is the OAuth1 consumer; Pesapal is the provider — unrelated to any SSO flow).

3.4 Specific authorization gaps found

Location	Issue
<code>AdminController.php</code>	~90 AJAX endpoints check token <i>presence</i> only, not validity/role — broad PII/financial data exposure surface

BrokerController.php	Only one endpoint (/getBrokerAccounttransactions) verifies resource ownership; write endpoints (/createagentaccount , /createAgentQuickLetter) don't check <code>userid > 0</code>
PurchasesController::get_token()	Copy/paste bug — returns empty string for POST-delivered tokens (only the GET branch works), silently breaking auth for POST callers
DocmakeController::/docmakeletter-covid	<code>verifyAccess()</code> result is computed but never checked — PDF served regardless of ownership
DocmakeController (otherwise)	Best-guarded controller in the app — correctly checks ownership/admin via <code>verifyAccess()</code> / <code>verifyAccessAdminBypass()</code> on every other route
TravelApiController	Best-guarded of all — explicit 401 on missing/invalid token before calling services

4. Core Business Workflow — Quote → Price → Pay → Issue

Two pricing engines exist side by side:

1. **Legacy local rating engine** — `rateClc()` / `rateClcCopacc()` query `Travelrates` (age/day/plan-banded lookup, not a formula) and `Calculationvariables` (child rate, postal charge, levy %, covid/winter-sport/golf surcharge %), then currency-convert via `Moneychanger`. Powers the instant public quote calculator and admin reporting. Day counts are "fudged" to band boundaries (45→43, 60→58, 90→88).
2. **Cygnit IMS v5 (authoritative)** — `TravelPlanService::getAvailablePlans()` → `ImsV5Client::getPlans()` returns fully priced plans. The real checkout endpoint (`/saveRate`) explicitly re-queries IMS rather than trusting any client-supplied or locally recomputed premium (code comment: *"Do not trust a browser-supplied premium... IMS has already priced the selected plan"*). An HMAC-signed, TTL-bound `TravelPlanService` selection token binds a quoted plan to its exact itinerary/traveler context between quote and purchase.

End-to-end flow

1. Customer fills the quote form (destinations, dates, traveler DOBs, trip type/plan) → `POST /travel/available-plans` (or legacy `/calculateRate`) → prices shown.
2. Customer picks a plan, enters traveler details (+ optional KYC file uploads to `kyc_uploads/kyc/`, unvalidated type/size) → `POST /saveRate` → re-validates price against IMS, creates `savedquotations` (status 0/unpaid), generates a policy number, persists one `travelinfo` row per traveler.
3. **Corporate/credit accounts** skip payment entirely — `BrokerController::createAgentQuickLetter()` prices via the flat daily rate, saves the quote, and immediately generates + emails the certificate and letter PDFs, billed later against the account.
4. **Retail customers** enter a mobile number → `POST /update-transaction-mobile` → `UgandaPaygateService::requestToPay()` triggers an MTN/Airtel mobile-money push via ICEA's own gateway.
5. Client polls `POST /check-payment-status` → `UgandaPaygateService::getTransactionStatus()` classifies the raw gateway status into `success` | `failed` | `pending` | `unknown` (configurable status-string lists via env vars). On success, `savedquotations.status` flips to `1` and `amountpayed` = `amountpayable`.
6. **Policy issuance:** `TravelContractService::issueForPaidQuotation()` calls `ImsV5Client::createContract()` — the actual policy-of-record issuance with the insurer's core system — then `emailContract()` so IMS itself emails the official documents. Idempotency is enforced via optimistic "claim" columns (`contract_status` : `PENDING`→`ISSUING`→`ISSUED`/`FAILED`; `email_status` : `PENDING`→`SENDING`→`SENT`/`FAILED`) to survive concurrent polling.

7. **Certificate/QR:** DocmakeController separately generates its own certificate/invoice/receipt/embassy-letter PDFs on demand (Dompdf + Endroid QR encoding a URL to the public `/certificate-validator/{id}` checker). **Three separate, non-unified document-generation code paths exist** (IMS's own PDF, Docmake's Dompdf+QR version, and the legacy Pesapal-flow's Dompdf-only version) — consolidate into one in the rebuild.

5. Database Schema

38 tables. Only **two real foreign-key constraints exist in the entire schema** (`travelinfo.quotationid` → `savedquotations.quotationid` CASCADE, and `travel_country_aliases.country_id` → `travel_countries.id` CASCADE) — every other relationship below is enforced only in application code, not the database. There is **no migration history**; this SQL dump is the sole source of truth, and it is more current/accurate than the Doctrine entity classes in several places (noted below).

5.1 Conceptual data model

```
adminroles —< admins (role) —< loginfo (userid)
      |
      └─ sessions [native PHP session store] / sessions1 [custom token t

adminlevels —< userlevelpermissions >— levelepermissions      (permission system #1 —
adminroles —< rolepermissionassignments >— rolepermissions    (permission system #2 —

intmed (brokers/agencies) —< clients (intermed/parentagency)
intmed —< coopaccounts (parentagency) —< copaccount_rates (rate-change history)
intmed —< agentdocuments (parentagency, accountid→coopaccounts) [corporate multi-t
      └─< corporate_multibook_data (traveller row

clients (quoterid) —< savedquotations —< travelinfo (FK CASCADE, one row per travell
      └─< declaration_of_health (informal link)
      savedquotations —< uganda_paygate_transactions (informal link
      savedquotations —< travel_contract_issuance (UNIQUE per quota

clients (userid) —< clickquotes [anonymous "quick quote" calculator submis

travelrates (age/day/plan-banded rate lookup)
benefits / placement_benefits (benefit schedules for PDF policy schedules)
calculationvariables (global pricing constants: levy, child rate, covid/winter-sport/g
zone_classifier (destination-zone classification for premium loading)
moneychanger (EUR→USD/KES/UGX/TZS FX rates)

country (legacy ISO lookup, barely used)
travel_countries —< travel_country_aliases (FK CASCADE) [new ISO3 resolver feeding

appconfig (global key/value settings incl. live API secrets, policy-number templates)
auditactivities (activity-type lookup) —< loginfo (action code)
visitations (site analytics tied to resolved country + client)
inquiries (public contact-form submissions, standalone)
superbrokers, accountoptions (seeded but effectively unused/orphaned)
```

5.2 Core tables — full detail

admins — internal staff & broker/agent users

Column	Type	Notes
adminid	int PK AI	
username, email	text / varchar(200)	
password	text	unsalted ripemd160 hash, or literal '0' when disabled
role	int, default 1	1 = Super User, 2 = Admin (also reused to mean "broker" via <code>brokerLogin()</code>)
department, location, profpic	varchar/text	
status	int, default 1	1 = enabled, 0 = disabled

clients — customers, brokers & agents

Column	Type	Notes
clientId	PK AI	
intermed	int, default 0	→ <code>intmed.intmedid</code> , which agency this client belongs to
clientname, surname, clientemail, phone	varchar/text	
clientsps	text	unsalted ripemd160 password hash
isbroker	int, default 0	0 = customer, 1 = broker/agent-flagged user
parentagency	int, default 0	→ <code>intmed.intmedid</code> (redundant with <code>intermed</code> in some flows)
isverified, isfirsttime	int	email-verified flag; first-login onboarding flag
joined	timestamp	default CURRENT_TIMESTAMP

savedquotations — the central quote/policy record

Column	Type	Notes
quotationid	bigint PK AI	
quoterid	int, indexed	→ <code>clients.clientId</code>
quotationpremium, quotationlevy, amountpayable	decimal(10,5)	
reasonfortravel	varchar(50)	Leisure / Business / Study
countryofdeparture, countryofdestination	varchar(100)	denormalized "Region;Country" string, e.g. Africa;Uganda
dateofdeparture, dateofreturn	date	
triptype	varchar(10)	SINGLETRIP / STUDENT / SG

tripplan	varchar(150)	display name, e.g. "Worldwide Silver"
status	int, default 0	0 pending 1 paid 2 cancelled 5 soft-deleted
isadminbooking	int, default 0	1 = booked via admin/agent "quick letter" flow
pesapalref, pesapalid	text	legacy Pesapal merchant/gateway ids
policynumber	text	generated from appconfig template + refindex
zone	text	AFRICA_ASIA / WORLDWIDE / IMS
cover_covid, winter_sport_cover, golf_cover	int	add-on toggles
covid_premium, winter_sport_premium, golf_premium	int	computed loadings from calculationvariables
travel_documents_sent_at/_to	datetime/varchar	set once paid; repository bug references a non-existent quotation_status column (should be status)

The Doctrine `Savedquotations` entity is stale — missing ~14 real columns (pesapalid, policynumber, zone, refindex, cover_*, *_premium, travel_documents_sent_*). All access to these happens via raw SQL in the repository, never the entity. **Do not treat the entity classes as schema truth for the rewrite — use this SQL-derived reference instead.**

travelinfo — one row per traveller on a quotation

FK to `savedquotations.quotationid` (CASCADE) — the only "real" FK on the core quoting tables. Columns: `recordid` PK, `quotationid`, `travelername`, `surname`, `othername`, `travelernationality`, `travelerpassport`, `idnumber`, `PIN`, `dob`, `travelerphone`, `traveleremail`, `travelerpostal`, `nextofkinname/phone/relationship`, `gender`, `passport_expiry`, `cost` (supports splitting group premium per traveller).

travelrates — rating table (no PK!)

No AUTO_INCREMENT/PK column — only a composite lookup index (`Trip_Type`, `plan_code`, `Min_Days`, `Max_Days`). Columns: `Min_Age`, `Max_Age`, `Min_Days`, `Max_Days`, `Trip_Type` (SINGLETRIP/STUDENT), `Trip_Plan`, `Zone`, `plan_code` (AFRICA_ASIA, EUROPE_BASIC/PLUS, WORLDWIDE_BASIC/SILVER/GOLD, STUDENT_WORLDWIDE), `plan_label`, `Premium`, `band_1..band_4` (per-traveller-count/class multipliers). Fixed 9-tier day-banding reused across every plan/zone: 1-8, 9-14, 15-21, 22-32, 33-49, 50-62, 63-92, 93-180, 181-365.

The `Travelrates` Doctrine entity declares a PK column `recid` that **does not exist** in the real table. This only "works" because the repository never uses ORM hydration for it — pure raw DBAL.

intmed — brokers/agencies master list

`recordid` PK, `intmedid` (business key referenced elsewhere, not the PK), `intmedname`, `intmedphone`, `intmedemail`, `dateofjoining`, `isactive`, `rate_per_day`, `requires_pay`. Seed includes ICEA LION itself (id 0, self-referential) plus real Kenyan brokers (Minet, Gras Savoye, Sedgwick, Zamara, etc).

coopaccounts / copaccount_rates — corporate accounts

`coopaccounts`: `accountid` PK, `parentagency` (→`intmed`), `accountname`, `accounttype` (1–4, meaning undocumented — confirm with business owner), `reformat`, `refstartindex`, `addedby`, `createddate`, `status`, `rate_per_day` (daily premium multiplier).
`copaccount_rates` is an append-only history of rate changes per account.

agentdocuments — corporate multi-traveller bookings

A parallel structure to `savedquotations` + `travelinfo` for the agent "quick letter" flow:
`recordid`, `agentid`, `parentagency`, `accountid`, `travellername`, `dob`, `travellerppno`, `datefrom/dateto`, `from/to`, `createdat`, `refindex`, `policynumber`, `status` (1 active, 2 cancelled), `is_multi_book`, `parent_record_id` (self-referential, links additional travellers to the first record), `cost`, `at_rate`.

uganda_paygate_transactions — mobile-money payment log

Column	Notes
<code>id</code> , <code>quotation_id</code> , <code>policy_no</code> , <code>mobile_no</code> , <code>amount</code> , <code>currency</code> (default UGX)	
<code>payment_gateway_id</code>	default 2 (Airtel-style gateway in sample data)
<code>xid</code> , <code>gateway_status</code> , <code>gateway_message</code>	raw upstream transaction id / status / human message
<code>payment_status</code>	INITIATED INIT_FAILED REQUESTED PAID FAILED
<code>raw_init_response</code> , <code>raw_status_response</code>	longtext, full JSON payloads persisted for audit

`UgandaPaygateService::classifyStatus()` normalizes raw gateway codes into buckets:
success = SUCCESS/SUCCESSFUL/PAID/COMPLETED/TS; **failed** = FAILED/FAIL/DECLINED/CANCELLED/CANCELED/TF; **pending** = TIP/PENDING/PROCESSING/INPROGRESS/IN_PROGRESS (overridable via env vars).

travel_contract_issuance — policy issuance tracking (MyISAM — outlier, no FK/transaction support)

`id`, `quotation_id` (UNIQUE — one contract per quotation), `payment_transaction_id` (intended link, unused), `ims_plan_id/type/name`, `currency_code`, `quoted_amount`, `contract_code`, `contract_url`, `create_attempts/email_attempts`, `last_error`, `contract_response/email_response` (json), `issued_at/mailed_at`.

State machines: `contract_status`: PENDING → ISSUING → ISSUED / FAILED (retry allowed after PENDING/FAILED, or if stuck ISSUING >5 min — an optimistic-lock/claim pattern)

to avoid duplicate issuance). `email_status` : PENDING → SENDING → SENT/FAILED, gated on `contract_status` = ISSUED first.

calculationvariables — global pricing constants

varname	value
childrate	0.50 (child premium = 50% of adult)
postalcharge	40.00
levy	0.45 (%)
currencyconv	1.00
sessiontimeout	30 minutes
covid_rate / covid_rate_usa / covid_rate_exusa	20.00 / 50.00 / 35.00
winter_sport_rate	40.00
golf_rate	10.00

appconfig — key/value settings

Includes App URL , `iframeLink` , `Pesapalprefix` (`ILT1-`), `policy_number_template` (`036A0555870*#`), `policy_number_corp_template` . **Contains live secrets in the dump** : PesaPal consumer key/secret, a SendGrid API key, and a mail credential password — must move to a secrets manager/env vars, never copy verbatim into the new repo.

moneychanger — FX rates

Base EUR, columns for `usd`, `kes`, `ugx`, `tsh`, `incremental` , dated rows (seeded 2019–2023). Used to localize premiums into UGX for the Uganda portal.

travel_countries / travel_country_aliases — new ISO resolver (actively used)

`travel_countries` : `id`, `name`, `official_name`, `common_name`, `normalized_name`, `iso2` (unique), `iso3` (unique), `numeric_code`, `active` . `travel_country_aliases` : `id`, `country_id` (FK CASCADE), `alias`, `normalized_alias` (unique). `CountryCodeResolver` uses these to turn legacy free-text (`"Asia;Azerbaijan"` , `"GB"`) into a canonical ISO3 for the IMS integration. This is the only cleanly-modeled reference data in the schema — **a good pattern to keep, and to extend with a real FK from `savedquotations` in the rewrite.**

Other tables (compact reference)

Table	Purpose	Key columns
<code>adminroles</code>	Role lookup	<code>roleid</code> , <code>rolename</code> (seed: 1 Super User, 2 Admin)
<code>adminlevels</code> / <code>levepermissions</code> / <code>userlevelpermissions</code>	Permission system #1 — half-seeded, not enforced	<code>levelid/levelname</code> ; <code>permid/permissionname/roles</code> ; join table

rolepermissions / rolepermissionassignments	Permission system #2 — half-seeded, not enforced	permid/permissiondescription; roleid↔permid join
superbrokers	Planned "super broker" tier — zero rows, unused	brokerid, username, email, password
sessions	Native Symfony/PHP session-handler table	sess_id PK, sess_data blob, sess_time, sess_lifetime
sessions1	Custom auth-token table (see §10 wiring bug)	sessionid, userid, token, validtill
corporate_multibook_data	Newer companion to agentdocuments for multi-traveller rows — looks unused	record_id, traveler_name, dob, passport_no, parent_record_id
declaration_of_health	Per-traveller medical/COVID declaration	record_id, parent_record_id, covid_status, existing_condition, condition_description
clickquotes	Anonymous "quick quote" calculator submissions (not full purchases)	clkid, userid, ratePlan, pricing fields stored as formatted currency strings e.g. 'Ugx 220,084.00'
benefits	Legacy benefit-amount lookup by plan/class	recordid, plan, class, amount
placement_benefits	Richer benefit schedule for PDF policy documents	record_id, section, benefits, category, excess, value
zone_classifier	Destination-zone classification for premium loading	record_id, zone (EXUSCA/EUROPE/INCUSCA), description
accountoptions	Seeded dropdown, not cross-referenced — likely unused	optionid, optionname (Classic/Plus/Standard/Premium)
country	Legacy ISO lookup, barely used by current logic	countrycode(ISO3) PK, countryname, code(ISO2)
inquiries	Public "Contact Us" submissions (only latin1- charset table)	inquiryid, byname, email, subject, msg, attime, isread
auditactivities / loginfo	Admin activity-type lookup / audit trail (646+ rows)	activityid/activityname; logid, userid, action, description, attime
letterprints	Tracks when an agent "quick letter" was printed	recordid, agentid, letterid, printedat
visitations	Site-visit analytics keyed to resolved country	visitationid, attimewhen, country, info(json), clientid

5.3 Status/enum reference (for the new schema's enums)

Field	Values
admins.status	1 enabled, 0 disabled
admins.role	1 Super User, 2 Admin
clients.isbroker	0 individual, 1 broker/agent
savedquotations.status	0 pending, 1 paid, 2 cancelled, 5 soft-deleted
agentdocuments.status	1 active, 2 cancelled
uganda_paygate_transactions.payment_status	INITIATED, INIT_FAILED, REQUESTED, PAID, FAILED
travel_contract_issuance.contract_status	PENDING, ISSUING, ISSUED, FAILED
travel_contract_issuance.email_status	PENDING, SENDING, SENT, FAILED
travelrates.plan_code	AFRICA_ASIA, EUROPE_BASIC, EUROPE_PLUS, WORLDWIDE_BASIC, WORLDWIDE_SILVER, WORLDWIDE_GOLD, STUDENT_WORLDWIDE

6. Backend Route / API Inventory

Grouped by controller. "Auth" reflects what is *actually enforced today*, not what's intended — see §3 for gaps.

IndexController.php — public site & core quote/purchase engine (~5,200 lines)

Route	Purpose	Auth
GET /, /home, /index	Home / quote wizard shell	none
GET /certificate-validator/{qr_code}	Public QR certificate authenticity check	none (by design)
GET /embassy-letter-validator/{qr_code}	Embassy letter check — <i>ignores the param, unfinished</i>	none
POST /signup, /felogin	Register / login (client)	n/a
POST /resetfepassword, /resetpassordaction	Password reset flow	none
POST /calculateRate	Retail instant quote calculator (legacy engine)	none
POST /calculateRateCopacc, /update-travel-dates	Corporate flat-rate calculator	token presence
POST /saveRate	Checkout/purchase-initiation — re-prices via IMS, uploads KYC files, creates the quotation	token presence
POST /savePrintRate	Legacy broker "print quote", still on old local calculator	encodeLab-obfuscated id (not JWT)
POST /update-transaction-mobile	Initiate mobile-money payment (Uganda Paygate)	token presence
POST /check-payment-status	Poll payment status → triggers contract issuance on success	token presence
POST /send_post_save_mail	Email documents post-payment (buggy error handling — references non-existent <code>\$this->logger</code>)	token presence
POST /saveinquiry, /getMyinfo, /verifyFeToken	Contact form, profile fetch, session heartbeat	varies

AdminController.php — back office (~5,500 lines, ~90 endpoints)

Group	Representative routes	Auth
-------	-----------------------	------

Auth	/trvadmin, /admin-auth, /loginAction, /lockLoginAction, /adminlogout	session/JWT
Dashboard/analytics	/basicHomeData, /getPageVisits, /getExchangeRateData, /getBuyComparison, /getMonthlyQuotesByTripPlan	none at all
Quotations	/adminpendingquotations, /adminpaidquotes[-lean], /admincancelledquotes, /adminbookings, /adminquoteview, /adminproposal, /cancelquote, /revert-cancelquote, /delete-quotes	token presence only
Customers	/adminAllCustomers, /adminindivcust, /adminagentcustomer, /adminCustomerProfile	token presence only
Agents/brokers	/adminagentmanagement, /adminAgentProfile, /createIntMedUserHcalc (broker invite, emails plaintext OTP), /adminagentwatch*	token presence only
Corporate accounts	/manageaccounts, /createagentaccountadmin, /activatecorpacc*, /deactivatecorpacc (registered twice — dead duplicate route), /save-cop-rate-admin, /getAgencyAccountsQuickAdmin*	only these 2 routes call isAdmin()
Internal staff	/adminusermanagement, /createUsercalc, /adminprofile, /adminprofileEditorcalc (unvalidated base64 file write)	token presence only
Settings	/adminappsettings, /getnewexchangeratescalc (hardcoded fixer.io key, plain HTTP)	token presence only

No rate-table (Travelrates/Calculationvariables) CRUD and no KYC-document routes exist in this controller at all — confirm whether that admin capability lives elsewhere before assuming parity in the rebuild.

BrokerController.php (~2,200 lines)

/BROKER, /broker (login), /brokerloginAction, /brokerhome, /brokerBooking, /brokerCopBooking, /brokerbookings, /corpaccounts, /brokeraccount, /createagentaccount, /getBrokerAccounttransactions (the one route with real ownership authorization), **/createAgentQuickLetter** (core instant-issue-on-credit corporate booking: price → save → generate certificate+letter PDFs → email, no payment gateway), /agentUserProfile. Four "cop"-prefixed pages (/copcorpaccounts , /copbrokeraccount , /copbrokerCopBooking , /copbrokerCopBookinglist) have **zero session guard**.

PurchasesController.php (~1,050 lines)

/purchases, /fecomprehensivepurchases, /febrokercomprehensivepurchases, /purchasescomprehensive, /quotedetails, **/showQuoteSummary** (the one IDOR-safe endpoint, checks `Clients::confirmCreator`). Contains a dead unused Selcom (Tanzania) helper.

PayGateController.php — legacy Pesapal (~750 lines)

/paygate, /paythank, /pesapallframeGet (OAuth1-signed request to Pesapal's deprecated XML API, recomputes payable amount server-side), /transactionsaver, /ipnreceiver (Pesapal webhook — on COMPLETED marks the quote paid and generates its own duplicate certificate/letter PDFs, emailed via Gmail SMTP). No auth on any route (public webhook by nature, but also true of the customer-facing ones).

DocmakeController.php — PDF/certificate/QR generation (~2,150 lines)

/docmakequote[-corp], /docmakeinvoice, /docmakereceipt, /docmakecert, /docmakeagentcert, /docmakeletter (modern, hardened — explicit exceptions, strict benefit validation, SSRF-hardened Dompdf config), /docmakeletter-covid (**auth check computed but never enforced**), /docmakeagentletter, plus `*Admin` / `*AdminBypass` variants correctly gated by `isAdmin()` . /docmakereport is effectively dead (its `verifyAccess(0,0)` always fails due to a PHP loose-equality quirk).

TravelApiController.php — the one modern, clean controller (83 lines)

POST /travel/available-plans → `TravelPlanService::getAvailablePlans()` . GET /travel/contract/{quotationId}/pdf → 401s cleanly on missing/invalid token, then streams via `TravelContractService::getContractPdfForQuotation()` . **Use this controller's shape (typed service delegation, explicit error envelopes, real 401s) as the pattern for every NestJS controller in the rebuild.**

Utility/dead classes

`JWT.php` (auth primitive, see §3), `encodeLab.php` (legacy ID obfuscation, see §3), `NavGeneratorController` (static PHP-array nav builder, not routed — see §8.3), `OrmOvr.php` / `OAuthController.php` / `selcom.php` / dead iotec.io code — all dead or dormant, do not port (see §10).

7. External Integrations

System	Direction	Purpose
Cygnets IMS v5	Outbound, this app is the client	Insurer's core system — authoritative pricing (<code>/api/v5/travel/plans</code>) and policy-of-record issuance (<code>/contract</code> , <code>/contract/email</code> , <code>/contract/pdf</code>). Bearer-token session cached to disk with lock-protected refresh.
"Uganda Paygate" cloud API (ICEA's own, <code>clientapi-cloud.icealion.com</code>)	Outbound	Primary mobile-money gateway: <code>/token</code> , <code>/requestToPay</code> , <code>/transactionStatus</code> (MTN/Airtel Uganda). This is the app's namesake and the actual payment rail — not a third party.
Pesapal	Outbound, OAuth1-signed	Legacy Kenyan card gateway (iframe checkout + IPN). Still wired but superseded for the primary flow.
Selcom	Outbound (dormant)	Tanzania mobile-money aggregator — helper class exists, call sites appear unused in this Uganda build.
iotec.io	Outbound (dead code)	Another East African mobile-money aggregator — full client implemented, not wired to any live route.
fixer.io	Outbound	Live FX rates — hardcoded API key, called over plain HTTP.
Gmail SMTP	Outbound	All transactional email via PHPMailer; credentials stored as DB config rows, not env vars.
Google Cloud Storage	Outbound (dead code)	Upload helpers exist but every call site is commented out — PDFs are never durably stored server-side, only emailed transiently.

8. Frontend Sitemap

Routing is 100% classic Symfony `#[Route]` attributes — no SPA router. Nearly every "AJAX" action is a `POST .../...calc` endpoint returning JSON (often with embedded HTML fragments — see §10) consumed by page-specific jQuery.

8.1 Public / customer site

Page	Purpose
Home (/)	5-step quote-and-buy wizard: 1) Itinerary (travellers, reason, nationality, destinations, dates) → 2) Quotation (plan selector, premium summary, USD/UGX toggle, COVID/Winter-sport/Golf add-ons) → 3) Billing account (login/signup gate) → 4) Client information (dynamic per-traveller rows) → 5) Confirmation (recap + T&Cs + submit)
Purchases / Purchases history	Logged-in customer's quote/purchase list, with a single-quote detail/summary view
Profile	Account settings
Login / Signup	Rendered as Bootstrap modals over the home page, not standalone pages
Password reset	Request + confirm flow, plus a small standalone "reset" mini-portal
Email confirmation landing pages	From invitation links, incl. a "force confirm" variant
Certificate / Embassy-letter validator	Public QR-scan authenticity checker pages
Payment (mobile money)	Modal-driven: network select → phone entry → poll for confirmation → success/failure state, "View policy PDF" link
Payment (legacy Pesapal)	Iframe checkout + "thank you" page + IPN log page
Error pages	404/500 (three redundant implementations — consolidate to one)

8.2 Admin portal

Page	Purpose
Login / Lock screen	Standard login + a "session expired but not logged out" lock screen
Dashboard	KPI widgets: page visits, exchange rates, buy comparison chart, monthly quotes by trip-plan chart
Click Quotes	Quotes started but never completed/paid (funnel drop-off report)

Pending / Paid / Cancelled Quotations	Full lifecycle views, incl. a "lean" lighter-column DataTable variant of Paid
Bookings	All admin-made bookings
Corporate / Individual Booking wizards	Admin books on behalf of a walk-in client or a corporate account
Customers (All / Individual / Agent-referred)	Client list views with a 360° customer profile page
Quote view / Proposal view	Single-quote detail/edit, pre-issue proposal document view
Edit sales transaction	Amend a booking's financial data
Agent management / Agent profile / Agent watch	Broker/agent oversight, incl. a production-monitoring dashboard with cancelled-view variant
Corporate account management	Activate/deactivate accounts, manage per-account daily rate
Internal user management	Staff account CRUD, role/level assignment
App settings	Exchange rates, general config
Admin profile	Photo, password change, and a "My Rights" badge list (see §8.3 — display-only, not enforced)

8.3 Broker portal

Page	Purpose
Login	Broker login
Dashboard	Broker landing
Individual / Corporate booking wizard	Broker books for a retail client or a corporate account
Bookings list	Broker's own bookings, plus a corporate bookings list
Corporate accounts	List + single-account detail/ledger (transaction view)
Profile	Broker's own profile

8.4 The permission-gated navigation system — what it actually does

The DB models a real RBAC scheme

(`adminroles` / `adminlevels` / `rolepermissions` / `rolepermissionassignments` / `userlevelpermissions`) and there's even a working query, `AdminsRepository::getMyRoles()` , that fetches permission descriptions for a role. But it is **display-only**: it feeds the "My Rights" badge list in the admin profile modal and nothing else.

The actual sidebar menu (`NavGeneratorController::defaultAdminNaviGen($role=null)` / `defaultbrokerNaviGen($role=null)`) is a **hardcoded PHP array**, and every one of the ~50 call sites passes `$role` as the literal `null` — the function doesn't even branch on it. **Every admin/broker sees the identical full menu regardless of role or permissions.**

This is dead/aspirational plumbing, not a working feature — treat it as a gap to actually implement in the rebuild (server-side permission check → filtered nav response), not a pattern to port as-is.

9. Design System — Colors, Typography, Layout KEEP FOR REBUILD

No CSS custom properties or SCSS variables exist anywhere in the codebase — every hex value below is a literal repeated (with some drift) across files. **Consolidate into a single token set for the React rebuild** rather than reproducing every drifted duplicate.

9.1 Color palette (verified from actual CSS)

 #003764	— primary navy (top-nav, table headers, footer, checkout banner) —	<i>the brand color</i>	 #c99c00	— email CTA button gold
 #001d35	— darker navy (checkout footer, table header rows)		 rgba(255,193,7)	— pending/attention status
 #005187	— navy hover/link accent		 rgba(40,167,69)	— success status
 #0f4673 /	— secondary blue accents		 #3c8dbc	— AdminLTE primary blue (admin buttons/labels)
 #3262b1 /	(switches, datepicker, scrollbar)		 #00a65a	— AdminLTE success
 #866000	— solid gold-brown (primary CTA buttons)		 #f39c12	— AdminLTE warning
 #a37e00	— lighter gold (links/labels, logo text "ICEA")		 #dd4b39	— AdminLTE danger
			 #00c0ef	— AdminLTE info
			 #2b2e34	— email header bar (distinct sub-palette)

Recommended token file for the rebuild

Token	Value	Usage
--color-primary	#003764	Header, nav, table headers, primary surfaces
--color-primary-dark	#001d35	Footers, darker surfaces
--color-primary-hover	#005187	Hover/active states, links
--color-accent	#866000	Primary CTA buttons
--color-accent-light	#a37e00	Secondary links/labels, brand wordmark
--color-success	#28a745	Paid/success states
--color-warning	#ffc107	Pending states
--color-danger	#dc3545	Failed/cancelled states

9.2 Typography

- **Public site:** Roboto (100–700 + italics) + Material Icons/Symbols, FontAwesome 4 for some icons
- **Admin & Broker:** Source Sans Pro (300/400/600/700 + italics) — AdminLTE 2.x default

- **Emails:** Varela Round + Questrial (a third, mostly-unused sub-palette — worth reconciling)

9.3 Frameworks in play

- Public site: custom Bootstrap-family CSS + jQuery (Select2, daterangepicker, Vegas.js background slider, a custom toggle-switch plugin, EU-cookie popup)
- Admin/Broker: **AdminLTE 2.x** + DataTables + pace.js loading bar
- `symfony/stimulus-bundle` , `asset-mapper`, and Turbo are installed dependencies but **functionally dead** — the demo Stimulus controller is untouched and unreferenced; all real interactivity is legacy jQuery loaded via classic `<script src>` tags outside the asset-mapper pipeline.

9.4 Layout / chrome structure to replicate as one parameterized shell

Portal	Chrome
Public site	Thin top bar (region/language + social icons) → main header (logo, primary nav, login/account control) → page content → 3-column footer (About/Related Links/Cross-sell) → copyright bar. Footer/nav bg: navy #003764.
Admin	AdminLTE shell: fixed header (logo, sidebar toggle, quick-links + user dropdown) + collapsible sidebar (user panel + permission-driven — <i>currently not actually filtered, see §8.4</i> — tree menu) + breadcrumb bar + content.
Broker	Inconsistent today: shares the public-site Bootstrap header/nav, but dashboard pages use the admin-style scripts/head include — the rebuild should pick one consistent broker shell rather than reproducing this mash-up.

The legacy app uses 8 near-duplicate Twig layout files (2 entirely unreferenced/dead) — the React rebuild should collapse these into a single `<AppShell variant="public | admin | broker | auth">` component.

10. Known Bugs & Legacy Issues — do NOT replicate

Unsalted ripemd160 password hashing everywhere → use bcrypt/argon2id.

Hardcoded/committed secrets: JWT signing secret in `.env` / `.env.local` ; AES key literal `'God Bless Kenya'` in `encodeLab.php` ; PesaPal keys + SendGrid API key + mail password stored as plaintext rows in the `appconfig` DB table; the Postman collection at repo root also contains a live-looking channel passkey and a bcrypt-looking auth key checked into source control.

Currency-conversion bug, duplicated in two places: UGX/TSH converted amounts are computed by adding the wrong currency's surcharge to the KES base instead of the UGX/TSH base — silently wrong displayed amounts across quotes, invoices, and admin reports.

Assignment-instead-of-comparison bug, `if ($results[0]['is_multi_book'] = 1)` , appears 4+ times across Admin/BrokerController — always truthy, silently disables the "single traveler" display branch.

Hardcoded-success bug: `IndexController::confirmregistrationexecute()` always returns success regardless of whether email verification actually succeeded.

Unchecked auth-result bug: `/docmakeletter-covid` computes `verifyAccess()` but never checks it — serves the PDF unconditionally.

Duplicate dead route: `/deactivatecorpacc` registered twice with the identical path — the second handler is unreachable under Symfony's first-match routing.

Dev-mode payment backdoor: `update_pay_details()` overrides the computed UGX amount with an env-configured test amount whenever `APP_ENV=dev` — verify absent from any production config, and don't reintroduce it.

sessions/sessions1 naming collision: the "auth token" repository methods (`createSession/verifySession/renewSession`) issue SQL against a table literally named `sessions` , but the columns they reference (`userid, token, validtill`) only exist on `sessions1` — the real `sessions` table is the unrelated native PHP session store. Verify this mechanism actually works today before porting it; it may be a dead/broken code path.

Other dead code, not worth porting: `OrmOvr.php` (broken PBKDF2 helper, would fatal in PHP 8 if called), `OAuthController.php` (789 lines, entirely unused duplicate OAuth1 library), `MarkdownHelper.php` (a stub), the `Article` entity/repository (no matching DB table exists at

all), duplicated date-formatting helpers

(`jDateMaker` / `jDateMakerWithTime` / `jDateMakerMiriam` / `jDateMakerMiriamWithTime`), three parallel `verifySession*()` implementations in `AdminController` (only one ever called), and numerous backup/dead template files (`bck.html.twig` , `Untitled-2.html` , ``agentcertbck`` , three redundant 404 pages, ``appz - Copy.js``).

Two parallel, largely unused RBAC schemas (`levels/levelpermissions` vs `roles/rolepermissions`) cover near-identical ground and are barely seeded — design one clean RBAC model for the rebuild rather than porting both.

Server-rendered HTML fragments embedded inside JSON responses throughout `Admin/BrokerController` (a `DataTables`-era pattern) — the new API contract should return structured status/action data, not markup strings.

11. UX Pain Points (rebuild backlog)

1. Full-page reloads everywhere despite Turbo being installed — no real SPA state model.
2. Permission-gated navigation is inert (§8.4) — every admin sees every menu item; worth actually implementing this time.
3. 8 near-duplicate layout files (2 entirely dead) — replace with one parameterized shell.
4. ~20 nearly-identical admin JS files, each hand-rolling its own DataTable + modal CRUD for a different entity — collapse into one generic, config-driven data table/CRUD component.
5. Fragile, ID-based jQuery selectors create implicit global coupling between header, wizard, and payment modal (the existence of a "hotfix" polling script patched in after the fact is itself evidence of this fragility).
6. Payment confirmation relies on client-side polling (5s interval, 60-attempt cap) with `localStorage` -persisted state, no push — a prime candidate for WebSocket/SSE in the rebuild for a snappier UX.
7. Admin DataTables are desktop-oriented with no responsive/stacked pattern (contrast with the public site's own responsive table CSS, never applied to admin).
8. Broker portal shell is an inconsistent mash-up of the public header + admin-style scripts — pick one.
9. Corporate/broker routes are duplicated at both root and `/broker` scope from an incomplete migration — treat the `broker/` subfolder versions as canonical.
10. Three redundant document-generation code paths (§4 step 7) and three redundant 404 implementations — consolidate each to one.

12. Recommended NestJS Backend Architecture

Decompose the ~2,000-line, ~80-method `SavedquotationsRepository` "god repository" (and the multi-thousand-line controllers) into focused modules:

NestJS module	Responsibility	Replaces
AuthModule	Real JWT (with enforced expiry!) via <code>@nestjs/jwt</code> + <code>@nestjs/passport</code> , bcrypt/argon2 password hashing, refresh tokens, role guards (Admin/Broker/Client), a genuinely-enforced permission system replacing the two dead RBAC schemas	JWT.php, SessionController, encodeLab.php, both permission table pairs
UsersModule (Admins/Staff)	Staff CRUD, roles, department/location	admins, adminroles
ClientsModule	Customer accounts, email verification, password reset	clients
AgenciesModule (Brokers/Intermediaries)	Agency master data, agent users, corporate sub-accounts and rate history	intmed, coopaccounts, copaccount_rates, superbrokers
QuotationModule	Quote creation, traveller records, declaration of health, status lifecycle (pending/paid/cancelled/deleted) as an explicit state machine/enum, not a bare int	savedquotations, travelinfo, declaration_of_health, clickquotes
CorporateBookingModule	Agent "quick letter" credit-billed bookings, independent of the payment flow	agentdocuments, corporate_multibook_data, letterprints
PricingModule	Rate-table lookup + pricing constants, exposed as one clean internal service (used until/unless IMS fully replaces it)	travelrates, calculationvariables, benefits, placement_benefits, zone_classifier
PaymentModule	Uganda mobile-money gateway client, transaction logging with a real status enum, webhook/polling endpoint, push updates via WebSocket/SSE instead of client polling	UgandaPaygateService, uganda_paygate_transactions
ContractModule	IMS v5 client, contract issuance state machine, one unified PDF/QR generation service (replacing 3 duplicated code paths)	lmsV5Client, TravelContractService, travel_contract_issuance, DocmakeController
GeoModule	Proper country entity + FK from quotations (no more <code>"Region;Country"</code> strings), alias-	travel_countries, travel_country_aliases, CountryCodeResolver, country

based fuzzy resolution kept as a genuinely good pattern

FxModule	Exchange-rate fetch/cache/history	moneychanger, fixer.io integration
ConfigModule	App settings via real env/secrets management, not a DB key-value table with plaintext secrets	appconfig
AuditModule	Structured activity logging (typed action enum, not a numeric string code)	auditactivities, loginfo
AnalyticsModule	Visitor/country tracking, dashboard KPIs	visitations

Cross-cutting recommendations: use TypeORM/Prisma migrations from day one (the legacy app's total lack of migration history is the single biggest operational risk found); make foreign keys real at the DB level (only 2 of dozens of implicit relationships are enforced today); model every "status" column as a TS enum + DB check constraint; return structured JSON only, never embedded HTML fragments; validate all file uploads (type/size) — KYC uploads currently aren't; put every current external API call behind an interface so Cygnet IMS, the mobile-money gateway, Pesapal, etc. are swappable/mockable in tests.

13. Recommended React Frontend Architecture

Apps/areas	Notes
Three route-guarded areas: <code>/</code> (public), <code>/admin</code> , <code>/broker</code>	Single React app with role-based routing (React Router + a route guard reading the JWT's role claim), or a monorepo with a shared design-system/component package — either is reasonable; a single app is simpler given how much UI (tables, modals) is shared in spirit today.
<code><AppShell variant></code>	Replaces the 8 legacy layout files: header/sidebar/footer composition driven by one prop, not 8 copy-pasted templates.
<code><QuoteWizard></code>	Replaces <code>appz.js</code> — the 5-step public quote/purchase flow. Use React Hook Form with a step-based schema (Zod/Yup per step), a <code>useFieldArray</code> for dynamic traveller rows (replacing <code>traveller-details.js</code>), and a derived-pricing hook that calls <code>/travel/available-plans</code> .
<code>usePaymentPolling()</code> + <code><PaymentModal></code>	Replaces <code>uganda-paygate-polling-hotfix.js</code> . Model explicitly as a state machine (XState is a good fit) mirroring <code>pending</code> → <code>attention/failed/success</code> ; prefer swapping the polling for a WebSocket/SSE push from the new <code>PaymentModule</code> .
<code><AdminDataTable></code> (generic, columns/endpoint-driven)	Replaces ~20 near-duplicate admin/broker JS files (<code>adminbookings.js</code> , <code>allQuotes.js</code> , <code>pendingquotes.js</code> , etc.) — one config-driven table+CRUD-modal component reused for quotes, customers, agents, corporate accounts.
<code><PurchasesTable></code>	React Query-backed customer purchase history + detail expansion.
Role-filtered sidebar nav	Fetch <code>{ role, permissions }</code> from the auth endpoint and filter a nav config tree client-side (or better, server-side) — actually implementing what §8.4 shows was never wired up in the legacy app.
Design tokens	Ship the palette in §9.1 as CSS variables / a Tailwind or MUI theme config from day one — do not hardcode hex values per component.
Certificate/QR validator pages	Keep as public, unauthenticated routes (<code>/certificate-validator/:code</code> , <code>/embassy-letter-validator/:code</code>) — genuinely useful, low-risk public utility.

14. Rebuild Checklist / Milestones

1. **Data model first:** stand up the NestJS entities from §5 with real FKs and enums, plus TypeORM/Prisma migrations — do not repeat the "no migration history" problem.
2. **Auth:** implement real JWT expiry enforcement, bcrypt hashing, and a role/permission guard system that's actually wired into route access (not just displayed as a badge list).
3. **Pricing:** port the `travelrates` / `calculationvariables` lookup as one clean PricingService; decide whether Cygnet IMS remains the authoritative external pricer/issuer (recommended, since it already is in production) and build a typed client for it plus the mobile-money gateway.
4. **Core quote → pay → issue flow:** rebuild end-to-end before touching admin/broker portals — it's the revenue path.
5. **Public site:** the quote wizard, purchases history, certificate validators.
6. **Admin portal:** start with the generic DataTable/CRUD component, then wire up each of the ~15 admin pages against it.
7. **Broker portal:** reuse the same generic components; resolve the current shell inconsistency by picking one design (recommend matching the admin AdminLTE-style shell, or a fresh shared shell, rather than the current public-header mash-up).
8. **Cut legacy integrations deliberately:** confirm with the business whether Pesapal, Selcom, and iotec.io are still needed before porting any of them — evidence suggests Selcom/iotec.io are already dead in production.
9. **Security pass:** rotate every secret currently embedded in `.env` / `appconfig` / the Postman collection before go-live; none of the current values should reach the new repo.

Compiled from a direct reading of the Symfony codebase, the MySQL schema dump, and the Postman collection in this repository. Treat every finding above as verified against source at the time of writing (2026-07-27) — re-check anything security-critical against the live app before acting on it.